

EventHub — White-Box Application Security Pentest Report

Project	EventHub (.NET API)
Repository	salihyigit1625/EventHub
Assessment type	White-box (source + live API retest)
Report date	21 August 2026
Status	Findings remediated across PR waves #1–#11

1. Executive summary

EventHub was assessed end-to-end across authentication, events/media, documents, ticketing, wallet/payments, waitlist, gate staff, organizers, admin, and domain business-logic integrity.

Initial testing identified **Critical** and **High** issues including:

- Account enumeration and weak password policy on registration
- Missing rate limits enabling brute-force / DoS
- Cross-organizer **IDOR** on event mutation (including cancel → mass refund)
- Poster **path traversal / arbitrary write** and unpublished content leaks
- Document arbitrary read by filename and attendee global download
- Ticket cancel / by-code IDOR
- Payment BOLA via ticket-id lookup
- Waitlist convert/notify ownership gaps
- Unscoped gate check-in
- Wallet lost-updates and double-refund race conditions

All in-scope remediation waves have been merged. Residual items are documented in §8 (low / intentional / deferred).

Severity snapshot (initial → final)

Severity	Initial (approx.)	Remaining in scope
Critical	Present (cancel IDOR + refund, document read, wallet races)	0
High	Multiple IDOR / upload / BOLA	0
Medium	Rate limits, sale windows, holds, quotas	0 (biz M1–M4 closed)
Low / Info	Date rules, paging, ID enumeration	Residual only (§8)

2. Scope & methodology

In scope

- REST API under `/api/*` (Auth, Events, Documents, Tickets, Wallet, Payments, Waitlist, GateStaff, Organizers, Admin)
- Domain business rules (inventory, refunds, check-in, waitlist holds)
- File upload/download pipeline (`uploads/`)

Method

1. White-box review of controllers, services, validators, seeders, EF configs
2. Live API abuse cases (`curl` / Swagger) with role tokens
3. Unit-test driven verification after each fix wave
4. Retest against ownership, status filters, upload sanitization, and concurrency guards

3. Remediation PR index

Use these links from finding cards below.

Wave	PR	Title
Auth	#1	Harden auth against enumeration, brute-force, weak credentials
Events / Media	#2	Strict ownership, secure upload pipeline, prevent unpublished leaks
Documents	#3	ID-based download ownership, magic-byte validation, anti-enumeration
Tickets	#4	Ticket ownership on cancel/code lookup, past-event purchase block
Wallet / Payments	#5	Payment BOLA → mine redesign, deposit cap, rate limits
Waitlist	#6	Convert/notify ownership, started-event join block, rate limits
GateStaff / Organizers	#7	Event-scoped check-in, admin-only organizer lookup, rate limits
Admin	#8	Event status + role checks on staff assign/create, rate limiting
Biz Critical	#9	Wallet lost-update + double-refund prevention
Biz High	#10	Waitlist holds, check-in window, cancel stock, atomic purchase/convert
Biz Medium	#11	Published ticket-type locks, per-user limits, waitlist rejoin, check-in claim

4. Findings by domain

Status legend: **Fixed** · **Partial** · **Accepted risk** · **Deferred**

4.1 Authentication (`/api/auth`)

Fix PR: [#1](#)

AUTH-01 — Account enumeration on register

--	--

Severity	Medium
Status	Fixed
Endpoints	POST /api/auth/register/attendee, POST /api/auth/register/organizer
Issue	Existing email returned 400 with explicit "A user with this email already exists.", enabling user discovery.
Evidence (pre-fix)	Register with admin@eventhub.local → 400 + verbose detail.
Remediation	Uniform responses / anti-enumeration messaging; aligned organizer path.

AUTH-02 — Weak password policy

Severity	Medium
Status	Fixed
Issue	Minimum length 6 with no complexity; password: "123456" accepted and issued tokens.
Remediation	Stronger password rules enforced at validation layer.

AUTH-03 — Missing rate limit (register / login)

Severity	Medium (brute-force / DoS)
Status	Fixed
Issue	Rapid sequential attempts returned 400 rather than 429; login open to online guessing.
Remediation	Auth rate-limit policies applied to register and login.

AUTH-04 — Mass assignment (roles / IsApproved)

Severity	Info (negative test)
Status	Not vulnerable
Issue	Injecting roles / organizer isApproved via JSON had no effect.

AUTH-05 — Logout does not revoke access token

Severity	Low / Medium
Status	Accepted / design note
Issue	Logout cancels refresh token; JWT access token remains valid until expiry (stateless JWT).
Note	Mitigated by short access-token lifetime; full revoke would need a denylist (deferred).

AUTH-06 — Refresh / Me

Severity	—
Status	No critical issues found

4.2 Events & media (/api/events)

Fix PR: [#2](#)

EVT-01 — Cross-organizer IDOR (update / publish / cancel / poster)

Severity	Critical / High
Status	Fixed
Issue	Organizer B could mutate Organizer A's eventId (update, publish, cancel, poster upload). Cancel triggered Paid → Refunded + wallet credit (financial impact).
Remediation	EventOwnership.EnsureOwnedBy on write paths; unauthorized → 401/404 per policy.

EVT-02 — Unpublished event / poster information disclosure

Severity	Medium / High
Status	Fixed
Issue	Anonymous GET /api/events/{id} and GET .../poster exposed Draft/Cancelled/Completed (and ticket types / posters). Public list also allowed unnecessary status filtering.
Remediation	Public reads → Published only ; draft readable by owner; poster download status-gated; public status query ignored; DB paging.

EVT-03 — Poster path traversal & arbitrary write

Severity	High
Status	Fixed
Issue	Multipart filename= with ../ / sub/../../poc.exe.png wrote outside intended layout; OS-level ../ blocks bypassed via Content-Disposition filename.
PoC (pre-fix, token redacted)	

```
curl -X POST 'http://localhost:8080/api/events/1004/poster' \
-H 'Authorization: Bearer <ORGANIZER_TOKEN>' \
-H 'Content-Type: multipart/form-data' \
-F 'file=@poc.exe.png;filename=sub/../../poc11.exe.png;type=image/png'
```

| **Remediation** | Discard client path; store `{Guid}-{safeExt}` ; confine under upload root; GUID eliminates overwrite collisions. |

EVT-04 — Extension bypass / missing magic-byte

Severity	Medium
Status	Fixed
Issue	*.exe.png passed extension checks; content type trusted from client.
Remediation	Extension allowlist + magic-byte (PNG/JPEG); content-type derived server-side.

EVT-05 — Upload memory / orphan / limits

Severity	Low / Medium
Status	Fixed
Issue	Full IFormFile buffered before DTO validation; old posters orphaned; no strict rate limit.
Remediation	Length/ext checks before copy; 10 MB request limits; delete previous poster; events-poster 5/min .

EVT-06 — Weak create/update date rules & published mutability

Severity	Low / Medium
Status	Fixed
Issue	Past starts / very long spans allowed; published events still updatable.
Remediation	Future StartDate, max duration 30 days ; published update forbidden .

EVT-07 — Mass assignment / verb tampering

Status	Not vulnerable (organizerId / status injection ineffective; customer verb tampering blocked)

4.3 Documents (/api/documents)

Fix PR: [#3](#)

ID	Finding	Severity	Status
DOC-01	GET ?fileName= arbitrary read under uploads	Critical	Fixed → GET /api/documents/{id} + ownership
DOC-02	Attendee global documents.download	High	Fixed (permission removed)

DOC-03	Upload size buffer before validate	High	Fixed
DOC-04	Predictable/overwriteable stored names	High	Fixed (GUID)
DOC-05	Extension bypass / no magic-byte (PNG/JPEG/PDF)	High	Fixed
DOC-06	Path / FilePath disclosure in DTO	Medium	Fixed
DOC-07	Missing rate limits	Medium	Fixed (documents-strict / documents-relaxed)

Access policy (post-fix): upload & download for **Admin + Organizer** only; download only if `UploadedByUserId == currentUser` (else **404**).

4.4 Tickets (/api/tickets)

Fix PR: [#4](#)

ID	Finding	Severity	Status	Notes
TKT-01	Cancel IDOR (no ownership)	P0 / High	Fixed	Owner-only; else 404
TKT-02	GET /by-code/{uniqueCode} IDOR	P0 / High	Fixed	Public lookup removed / owner-only; gate uses check-in
TKT-03	Purchase allowed after event start	P1	Fixed	Pre-start required
TKT-04	Multi-SaveChanges / race	P1	Fixed (+ later biz H5)	Transaction hardening
TKT-05	No rate limit	P2	Fixed	strict / relaxed policies
TKT-06	No per-user purchase cap	P2	Fixed in #11	MaxTicketsPerUser

Already solid (pre-fix): Published-only purchase, sale window, stock, wallet balance, cancel only for Paid + deadline, mine scoped to self.

4.5 Wallet & payments

Fix PR: [#5](#) · concurrency follow-up [#9](#)

ID	Finding	Severity	Status
PAY-01	GET /payments/ticket/{ticketId} BOLA	P0	Fixed → GET /api/payments/mine

WAL-01	Deposit no upper bound (demo free-money)	P1	Fixed (max deposit constant)
WAL-02	Rate limit missing	P2	Fixed
WAL-03	Wallet lost-update (no RowVersion)	Critical (biz)	Fixed in #9

Already solid: balance / transactions scoped to `currentUser` ; deposit cannot target another wallet.

4.6 Waitlist (`/api/waitlist`)

Fix PRs: [#6](#) · holds/sale window [#10](#) · filtered unique [#11](#)

ID	Finding	Severity	Status
WL-01	Convert IDOR	P0	Fixed
WL-02	Notify-next without event ownership	P0	Fixed
WL-03	Join/convert without start/sale alignment	P1	Fixed
WL-04	Rate limit missing	P2	Fixed
WL-05	Notify without stock hold (purchase steal)	High (biz H1)	Fixed in #10
WL-06	Unfiltered unique blocked Expired re-join	Medium (biz M3)	Fixed in #11

4.7 GateStaff & organizers

Fix PR: [#7](#) · window/claim [#10](#) / [#11](#)

GateStaff

ID	Finding	Severity	Status
GS-01	Check-in without assigned-event scope	P0	Fixed
GS-02	Null assignment → global check-in	P0	Fixed
GS-03	Cancelled/Completed event still check-in	P1	Fixed
GS-04	No Start/End window	High (biz H2)	Fixed in #10
GS-05	Concurrent double check-in race	Medium (biz M4)	Fixed in #11
GS-06	Rate limit	P2	Fixed

Already solid: non-GateStaff role blocked; invalid ticket statuses fail + log; `GET assigned-event` is self-only.

Organizers

ID	Finding	Severity	Status
----	---------	----------	--------

ORG-01	GET /organizers/{userId} leaks TaxNumber/email (BOLA/enum)	P0	Fixed (Admin-only)
ORG-02	PUT /organizers/me cross-user update	—	Not vulnerable
ORG-03	Rate limit	P2	Fixed

4.8 Admin (/api/admin)

Fix PR: [#8](#)

Endpoint	Result (pre-fix)	Post-fix
GET .../organizers/pending	Admin-only OK	+ rate limit
POST .../organizers/{id}/approve	Double-approve blocked; Admin-only OK	Role checks tightened as needed
GET .../stats	Admin-only OK	+ rate limit (memory aggregation accepted)
POST .../gate-staff	Password hashed; no password in response	Event must be valid/assignable status
POST .../gate-staff/assign	Entity existence OK	Event status + GateStaff role enforced

No classic Admin role-bypass / IDOR found; remaining gaps were status/role validation and rate limits → **Fixed**.

4.9 Business logic integrity

ID	Topic	Severity	PR	Status
C1	Wallet concurrency (RowVersion / lost-update)	Critical	#9	Fixed
C2	Double refund (ticket cancel × event cancel)	Critical	#9	Fixed
H1	Waitlist notify stock reserve / hold / release	High	#10	Fixed
H2	Check-in StartDate–EndDate window	High	#10	Fixed
H3	Waitlist sale window aligned with purchase	High	#10	Fixed
H4	Event cancel stock restore + CheckedIn refund policy	High	#10	Fixed
H5	Purchase/Convert single DB transaction	High	#10	Fixed
M1	Published ticket-type Price/TotalQuantity lock	Medium	#11	Fixed
M2	Per-user ticket quota (MaxTicketsPerUser)	Medium	#11	Fixed
M3	Status-filtered waitlist unique (Expired re-join)	Medium	#11	Fixed

M4	Check-in claim + RowVersion concurrency	Medium	#11	Fixed
-----------	---	--------	---------------------	-------

H4 policy (implemented): event cancel refunds **Paid and CheckedIn**, credits wallet once via refund guards, and restores `RemainingQuantity` per refunded ticket.

5. Consolidated severity → status matrix

#	Domain	Finding	Severity	Status	PR
1	Events	Cancel IDOR + mass refund	Critical/High	Fixed	#2
2	Documents	Filename arbitrary read	Critical	Fixed	#3
3	Biz	Wallet lost-update / double refund	Critical	Fixed	#9
4	Events	Poster path traversal	High	Fixed	#2
5	Events	Update/publish/poster IDOR	High	Fixed	#2
6	Tickets	Cancel / by-code IDOR	High	Fixed	#4
7	Payments	Ticket payment BOLA	High	Fixed	#5
8	Waitlist	Convert / notify IDOR	High	Fixed	#6
9	GateStaff	Unscoped check-in	High	Fixed	#7
10	Organizers	Profile GET sensitive leak	High	Fixed	#7
11	Auth	Enumeration / weak password / no RL	Medium	Fixed	#1
12	Events	Unpublished GET/poster leak	Medium/High	Fixed	#2
13	Biz High	Holds, windows, atomicity (H1-H5)	High	Fixed	#10
14	Biz Medium	Locks, quotas, rejoin, check-in claim	Medium	Fixed	#11
15	Admin	Assign/create without status/role checks	Medium	Fixed	#8

6. Retest checklist (smoke)

- ✓ Organizer B → A's event update/publish/cancel/poster → denied
- ✓ Anonymous draft GET {id} / draft poster → 404
- ✓ Traversal/ exe.png poster upload → rejected; no write outside upload root
- ✓ Document download other user's id → 404; Attendee download forbidden
- ✓ Ticket cancel / by-code foreign ticket → 404
- ✓ Payments mine only returns caller's receipts
- ✓ Waitlist convert/notify foreign resource → denied
- ✓ Gate check-in without matching assignment → fail + log
- ✓ Organizer GET by id as non-admin → denied
- ✓ Parallel wallet ops / double refund paths → concurrency / guard safe
- ✓ Waitlist notify holds stock; purchase cannot steal hold

- ☒ Check-in outside Start/End → rejected
- ☒ Published ticket-type price/qty mutation → rejected
- ☒ Per-user purchase over limit → rejected
- ☒ Expired waitlist re-join → allowed

7. Rate-limit posture (post-remediation)

Area	Policy intent (examples)
Auth	Register/login throttling → 429 under abuse
Events write	~20/min
Poster upload	Strict ~5/min
Events/docs read	Relaxed ~60/min
Documents upload	Strict
Tickets / wallet / waitlist / gate / admin	Strict on mutating, relaxed on reads

Exact numeric policies live in `Program.cs` rate-limiter configuration.

8. Residual risks & deferred items

Item	Severity	Disposition
Stateless JWT access token until expiry after logout	Low/Med	Accepted (short TTL)
Sequential numeric IDs (enumeration of existence)	Info	Accepted; unpublished now 404
CancellationDeadlineHours = 0 still allowed	Low	Product decision
Image polyglot with valid magic header	Low	Accepted
Admin stats / some lists still memory-aggregated	Perf	Deferred scale work

9. Conclusion

EventHub's security posture moved from **multiple Critical/High IDOR and file-write findings** to a **defensible API baseline**: object-level ownership, published-only public reads, hardened uploads, rate limits, and business-logic concurrency/idempotency for wallet, refunds, inventory holds, and check-in.

Remediation is traceable via merged PRs [#1–#11](#). Further work should focus on residual JWT revoke strategy (if required), operational monitoring of rate-limit hits, and product decisions listed in §8.
